

ISO 21434 TARA Threat Analysis

https://gemini.google.com/app/627ade1c7f303939

User prompt: Act as a Senior Automotive and IoT Cybersecurity Engineer conforming to the ISO/SAE 21434 standard. Perform a preliminary Threat Analysis and Risk Assessment (TARA) — specifically Threat Identification and Damage Scenario formulation — for the system architecture modeled in Ansys Medini Analyze described below. ### System Architecture Overview The system is a multi-tier environmental/indoor monitoring platform featuring dual-path edge-to-cloud telemetry: Central Processing Unit: «Controller» Indoor Unit (IUC) Sensing Subsystem (connected to IUC): Particulate matter: PM2.5, PM10 Toxic/ambient gases: CO, CO2, NO2, SO2, O3 Geolocation: «Component» GPS (bidirectional interface with IUC) Actuation Subsystem: «Actuator» Status Display (controlled directly by IUC via Display In/Out lines) Uplink Path A (Local Edge / Cellular): IUC <-> «Component» Wi-Fi <-> «Controller» Far edge device <-> «Component» 4G <-> «Item/System» Cloud server Uplink Path B (LPWAN): IUC <-> «Component» LoRaWAN <-> «Component» LoRa GW <-> «Item/System» LoRa edge server <-> «Item/System» Cloud server Backend & Consumer Tier: «Item/System» Cloud server <-> «Item/System» User (dashboard / client application) Task Scope & Objectives 1. Apply the STRIDE threat modeling methodology systematically across: - Physical/analog sensor interfaces and buses to the IUC. - Local wireless channels (Wi-Fi, LoRaWAN, Cellular 4G, GPS RF signals). - Intermediate computing nodes (Far edge device, LoRa Gateway, LoRa edge server). - Cloud backend endpoints and end-user data delivery channels. 2. Formulate clear Threat Scenarios and map each to a concrete Damage Scenario considering vehicle/system-level safety, operation, financial impact, and user privacy (SFOP). ###Output Format Provide the results in a structured Markdown table compatible with Ansys Medini Analyze TARA tables, using the following columns: | Threat ID | Target Element / Interface | STRIDE Category | Compromised Asset & Property (Confidentiality, Integrity, Availability, Authenticity) | Threat Scenario Description | Damage Scenario (Vehicle / Passenger / Operational Impact) | |---|---|---|---|---|---| Ensure deep technical coverage of: - Sensor data spoofing/tampering (especially safety-critical gases like CO and toxic pollutants) causing suppressed alerts or false status indications on the Status Display. - Wireless jamming, replay, and eavesdropping attacks on LoRaWAN, 4G, Wi-Fi, and GPS. - Compromise or lateral movement via intermediate processing nodes (Far edge device, LoRa Edge server). Note: Please remember that there must not be any threads with more than one STRIDE category! One category per thread.

Response: This preliminary Threat Analysis and Risk Assessment (TARA) adheres strictly to **ISO/SAE 21434 [Clause 15]**, addressing Asset Identification, Threat Scenario formulation, and Damage Scenario mapping across Safety, Operational, Financial, and Privacy (SFOP) impacts.

Preliminary Threat Analysis & Damage Scenario Table (Ansys Medini Analyze Model Schema)

Each threat ID maps strictly to **exactly one STRIDE category** per entry.

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (SFOP Impact Analysis)
THR_SENS_01	Gas Sensors (CO, NO2, SO2) <-> IUC Analog/ADC Bus	Tampering	Gas Measurement Telemetry Data (Integrity)	Attacker applies hardware voltage offset/injection on the ADC trace or sensor bridge to artificially depress gas readings.	Safety (Severe) / Operational: Acute CO or toxic gas accumulation goes undetected inside the cabin/enclosure. Automatic HVAC ventilation triggers fail to actuate, leading to severe passenger hypoxia, toxic exposure, or loss of life.
THR_SENS_02	Particulate Matter Sensors (PM2.5/PM10) <-> IUC I2C/UART Bus	Spoofing	Sensor Data Frame Payload & Origin (Authenticity)	Attacker impersonates the PM sensor module on the internal digital bus, injecting false baseline ambient air quality readings.	Operational / Financial: False clean air metrics delay automated cabin air filtration/recirculation, leading to respiratory discomfort and potential long-term liability/regulatory penalties.

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (SFOP Impact Analysis)
THR_SENS_03	GPS Antenna / RF Receiver Interface	Spoofing	Geolocation Data & NMEA Telemetry (Authenticity)	Attacker uses a portable Software Defined Radio (SDR) to transmit malicious GPS RF signals (GPS Spoofer), overriding legitimate satellite signals.	Operational / Privacy: The system records false spatial coordinates for critical toxic gas exposure events. Contaminant mapping becomes invalid, preventing emergency response to true danger zones and obfuscating fleet position tracking.
THR_SENS_04	GPS RF Interface	Denial of Service	Satellite Positioning Signal (Availability)	Attacker broadcasts broadband noise on the GPS L1/L5 frequency bands (RF Jamming), disrupting carrier tracking loops.	Operational: Total loss of live geolocation tagging for air quality telemetry; forces system fallback to degraded state or inaccurate dead reckoning.
THR_ACT_01	IUC <-> Status Display Interface (Display In/Out Lines)	Tampering	Display Driver Output Commands (Integrity)	Attacker injects malicious display control signals over SPI/RGB lines to display false "NORMAL" air status despite hazardous gas alerts.	Safety (Moderate) / Operational: Occupants rely on visually misleading dashboard status and do not evacuate or manually trigger ventilation during toxic gas release events.
THR_ACT_02	Status Display Module Firmware Interface	Information Disclosure	Display Framebuffer & Operational State (Confidentiality)	Attacker taps display readout telemetry to infer internal system state, thresholds, and operational diagnostics.	Privacy / Operational: Discloses internal vehicle/facility usage patterns and environmental baseline profiles to unauthorized third parties.
THR_WIFI_01	Wi-Fi Interface (IUC <-> Far Edge Device)	Tampering	In-Transit Telemetry Data (Integrity)	Attacker executes a Man-in-the-Middle (MitM) attack or arp/DNS spoofing on the Wi-Fi link to alter environmental readings before cellular transmission.	Operational / Financial: Cloud backend receives manipulated gas trends, causing incorrect automated HVAC dispatch, false environmental warnings, and unnecessary maintenance callouts.
THR_WIFI_02	Wi-Fi Interface (IUC <-> Far Edge Device)	Denial of Service	Wi-Fi Channel Bandwidth (Availability)	Attacker executes continuous 802.11 Deauthentication frame injection or RF jamming on 2.4/5GHz bands.	Operational: Disruption of local edge communication channel forces uplink failover to LPWAN (Uplink Path B), reducing bandwidth and telemetry

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (SFOP Impact Analysis)
					sampling frequencies.
THR_LORA_01	LoRaWAN Wireless Link (IUC <-> LoRa GW)	Repudiation	Transmitted Message Event Log (Repudiation)	Malicious or compromised device transmits invalid or malicious alarm packets and denies sending them due to weak frame sequence verification or missing nonces.	Operational: Inability to audit historical emergency events or attribute rogue transmissions during forensic investigations.
THR_LORA_02	LoRaWAN Wireless Link (IUC <-> LoRa GW)	Information Disclosure	Unencrypted Sensor Telemetry (Confidentiality)	Attacker sniffs raw LoRa RF frames using an eavesdropping receiver when weak or default AppKeys/NwkSKeys are deployed.	Privacy: Exposes detailed spatio-temporal environmental data, occupancy patterns, and facility operational schedules to unauthorized eavesdroppers.
THR_LORA_03	LoRaWAN RF Spectrum (868/915 MHz)	Denial of Service	Physical RF Medium (Availability)	Attacker deploys a continuous high-power RF jammer targeting Sub-GHz LoRaWAN channels.	Operational: Complete denial of primary or backup LPWAN telemetry path, isolating remote nodes during cellular outages.
THR_4G_01	Cellular 4G Module (Far Edge <-> Cloud Server)	Elevation of Privilege	Baseband Controller & APN Configuration (Elevation of Privilege)	Attacker exploits an unpatched vulnerability in the cellular baseband stack to gain root shell execution on the cellular modem.	Safety / Operational: Compromised baseband allows full control over the Far Edge Device, enabling lateral pivot into the IUC via Wi-Fi and modification of critical safety threshold triggers.
THR_EDGE_01	Far Edge Device (Edge Computing Node)	Spoofing	Device Identity & Authentication Tokens (Authenticity)	Attacker extracts hardcoded certificates/keys from the Far Edge flash memory to impersonate a legitimate edge node to the Cloud Server.	Financial / Operational: Attacker injects massive volumes of synthetic telemetry into the backend, inflating cloud operational costs and corrupting enterprise analytics platforms.
THR_EDGE_02	Far Edge Device Local Storage / OS	Tampering	Edge Processing Logic & Local Rules Engine (Integrity)	Attacker exploits weak local authentication to modify edge aggregation scripts and threshold evaluation routines.	Safety / Operational: Local edge emergency decision logic fails to alert local actuators or trigger emergency cloud RPC calls during hazardous gas spikes.

Threat ID	Target Element / Interface	STRIDE Category	Compromised Asset & Property	Threat Scenario Description	Damage Scenario (SFOP Impact Analysis)
THR_LORA_SRV_01	LoRa Edge Server	Elevation of Privilege	LoRaWAN Network/App Server Runtime (Elevation of Privilege)	Attacker exploits a container breakout or remote code execution (RCE) vulnerability in the LoRa Edge Server stack.	Financial / Operational / Privacy: Attacker gains full administrative control over all managed gateways, granting the ability to manipulate, drop, or siphon data across the entire LPWAN fleet.
THR_CLOUD_01	Cloud Server API Endpoints	Spoofing	Cloud Ingestion Service & JWT Auth Tokens (Authenticity)	Attacker performs API key harvesting or token forgery to inject fraudulent data streams directly into cloud database tables.	Operational / Financial: Enterprise-wide corruption of environmental monitoring records, leading to non-compliance fines from regulatory authorities and incorrect safety decisions.
THR_CLOUD_02	Cloud Server Database Store	Information Disclosure	Aggregated Environmental & User Location Data (Confidentiality)	Attacker exploits SQL injection or misconfigured S3 access control policies on backend storage buckets.	Privacy / Financial: Mass exposure of historical geolocation traces and user exposure history, leading to GDPR/privacy regulation breach penalties and reputational loss.
THR_CLOUD_03	Cloud Server <-> User Application Channel	Denial of Service	Application API Availability (Availability)	Attacker launches a Distributed Denial of Service (DDoS) attack against public dashboard endpoints.	Operational: Live alerts and safety dashboards are unreachable by end users and facility operators during critical environmental incidents.
THR_USER_01	User Client Application / Dashboard	Elevation of Privilege	User Access Control & Session Management (Elevation of Privilege)	Attacker exploits broken object-level authorization (BOLA/IDOR) to escalate privileges from a standard viewer to an enterprise administrator.	Operational / Safety: Attacker remotely reconfigures global toxic gas thresholds, silences safety alarms, and alters display settings across all connected vehicles/units.

User prompt: i need you to tell me the total number of spoofing, tampering ... etc for all the stride letters. just count them for me and tell me how many for each actegory

Here is the exact count of threat scenarios for each STRIDE category from the preliminary TARA table:

STRIDE Letter	STRIDE Category	Count	Associated Threat IDs
S	Spoofing	4	THR_SENS_02, THR_SENS_03, THR_EDGE_01, THR_CLOUD_01
T	Tampering	4	THR_SENS_01, THR_ACT_01, THR_WIFI_01, THR_EDGE_02
R	Repudiation	1	THR_LORA_01
I	Information Disclosure	3	THR_ACT_02, THR_LORA_02, THR_CLOUD_02
D	Denial of Service	4	THR_SENS_04, THR_WIFI_02, THR_LORA_03, THR_CLOUD_03
E	Elevation of Privilege	3	THR_4G_01, THR_LORA_SRV_01, THR_USER_01
Total		19	

Breakdown Highlights

- **Spoofing (4):** Targets sensor identities, GPS RF signals, edge device credentials, and cloud API endpoints.
 - **Tampering (4):** Focuses on analog bus signal offset/injection, display control signals, in-transit telemetry, and edge logic scripts.
 - **Repudiation (1):** Covers unauthenticated or non-sequenced LoRaWAN frame injection lacking strong audit trails.
 - **Information Disclosure (3):** Spans display state leakage, unencrypted LoRaWAN payload sniffing, and cloud database exfiltration.
 - **Denial of Service (4):** Encompasses GPS jamming, Wi-Fi deauth/jamming, Sub-GHz LoRaWAN RF jamming, and cloud API DDoS attacks.
 - **Elevation of Privilege (3):** Involves cellular modem baseband exploits, LoRa edge server container breakouts, and web app BOLA/IDOR privilege escalation.
-